Script-Controlled ACL – Restrict Record Access Based on Field Value

ServiceNow Security Automation / Access Control Lab

PROJECT OVERVIEW

This project demonstrates how Script-Controlled Access Control Lists (ACLs) in ServiceNow can be used to restrict access to records according to user roles and a record field value. In this scenario, users with the custom bb1 role are permitted to read EEE branch records, while administrators retain full access. Additional bb2, bb3 and bb4 roles control Create, Write and Delete operations respectively.

Project Title

Script-Controlled ACL – Restrict Record Access Based on Field Value

Platform

ServiceNow

Duration

3 Hours

Main Security Concept

Role-based and script-controlled record-level access

1. BRAINSTORMING & IDEATION PHASE

1.1 Problem Identification

In a service management platform, users should not automatically receive access to every record. Sensitive institutional records may need to be restricted based on the user's role and a field such as Branch.

1.2 Proposed Idea

Create a custom Institution Details table and use ServiceNow ACLs to control Read, Create, Write and Delete operations. The access model uses custom roles bb1–bb4 and a script-controlled condition for EEE branch records.

1.3 Objectives

- Create test users and custom security roles.
- Create a custom Institution Details table.
- Store student information with ECE, EEE and CSE branch values.
- Restrict Read access using an ACL and script.
- Control Create, Write and Delete operations through separate ACLs.
- Allow administrators to retain full access.
- Verify the security rules through impersonation and list/form access.

1.4 Expected Outcome

Only authorized users should be able to perform the operations assigned to their roles, while unauthorized users are prevented from accessing protected records.

2. REQUIREMENT ANALYSIS PHASE

2.1 Functional Requirements

- Admin must be able to create users and roles.
- Admin must be able to create the custom u_institution_details table.
- Records must contain student details and a Branch value.
- Read access must be controlled using an ACL.
- Create access must require bb2.
- Write access must require bb3.
- Delete access must require bb4.
- Administrators must retain full access.
- Access must be verified by impersonating different users.

2.2 Security Requirements

- Unauthorized users must not access protected records.
- Role requirements must be evaluated by ServiceNow ACLs.
- Record-level access must depend on the configured Branch rule.
- Security testing must cover Read, Create, Write and Delete operations.

2.3 User and Role Requirements

- Test user: EEE User
- User ID: EEE User
- Email: eeeuser@gmail.com
- Custom roles: bb1, bb2, bb3, bb4
- All required roles can be assigned to the test user for progressive verification.

2.4 Table Requirements

Table Label: Institution Details

Table Name: u_institution_details

- Student Roll Number – Auto Number
- Student Name – Reference: User
- Faculty Name – Reference: User
- Branch – Choice: ECE, EEE, CSE
- Email – String
- Phone Number – String
- Description – Multi String

3. PROJECT DESIGN PHASE

3.1 System Design

User → ServiceNow Authentication → Role Evaluation → ACL Evaluation → Record/Operation Check → Allow or Deny Access.

3.2 Security Architecture

- bb1 → Read access for the configured EEE record condition.

- bb2 → Create access.
- bb3 → Write/Edit access.
- bb4 → Delete access.
- admin → Full access according to the administrator rule.

3.3 Read ACL Logic

The Read ACL uses Advanced scripting. The intended logic is: administrators are allowed; users with bb1 are allowed according to the configured EEE data condition; other users are denied.

3.4 ACL Operations

Operation	Required Role	Purpose
Read	bb1	Access permitted for EEE records under the configured condition
Create	bb2	Create new records
Write	bb3	Edit existing permitted records
Delete	bb4	Delete permitted records
Administrator	admin	Full administrative access

4. PROJECT PLANNING PHASE

4.1 Implementation Plan

1. Create the ServiceNow test user.
2. Create bb1, bb2, bb3 and bb4 roles.
3. Assign the required roles to the test user.
4. Create the Institution Details table.
5. Create the required table fields.
6. Insert records with ECE, EEE and CSE branch values.
7. Create and test the Read ACL.
8. Create and test the Create ACL.
9. Create and test the Write ACL.
10. Create and test the Delete ACL.
11. Impersonate users and verify permissions.
12. Capture screenshots and prepare the final documentation.

4.2 Time Plan

Activity	Planned Time
User and role creation	20 min
Table and fields	30 min
Sample records	15 min
Read ACL	30 min
Create/Write/Delete ACLs	45 min
Testing and screenshots	30 min
Documentation	10 min

5. PROJECT DEVELOPMENT PHASE

5.1 Milestone 1 – User Creation

13. Log in to the ServiceNow instance with admin access.
14. Navigate to User Administration → Users.
15. Click New.
16. Create the EEE User with the required user details.
17. Save the record.

5.2 Milestone 2 – Role Creation

18. Navigate to User Administration → Roles.
19. Click New.
20. Create role bb1 and provide a suitable description.
21. Create bb2, bb3 and bb4 using the same procedure.
22. Assign the required roles to the EEE User.

5.3 Milestone 3 – Table Creation

23. Open System Definition → Tables.
24. Click New.
25. Set Label to Institution Details.
26. Set Name to u_institution_details.
27. Keep Extends for as false.
28. Submit the table.
29. Add all required fields.

5.4 Milestone 4 – Sample Records

Create multiple records containing different Branch values such as ECE, EEE and CSE.

5.5 Milestone 5 – Read ACL

- Navigate to System Security → Access Control (ACL).
- Elevate the security_admin role.
- Create a record-level Read ACL for u_institution_details.
- Set Active to true and Advanced to true.
- Add bb1 in Requires role.
- Configure the Branch data condition as EEE.
- Use the administrator/full-access and bb1 authorization logic in the Advanced script.
- Submit the ACL.

5.6 Milestone 6 – Create ACL

- Create a record-level Create ACL for u_institution_details.
- Set Active to true.
- Add bb2 in Requires role.
- No additional Branch data condition is required for this ACL.
- Save the ACL.

5.7 Milestone 7 – Write ACL

- Create a record-level Write ACL for u_institution_details.

- Set Active to true.
- Add bb3 in Requires role.
- No additional Branch data condition is required for this ACL.
- Save the ACL.

5.8 Milestone 8 – Delete ACL

- Create a record-level Delete ACL for u_institution_details.
- Set Active to true.
- Add bb4 in Requires role.
- No additional Branch data condition is required for this ACL.
- Save the ACL.

6. PROJECT TESTING PHASE

6.1 Testing Method

Testing is performed by impersonating users with different role combinations and opening the u_institution_details list/form. The objective is to confirm that the ACL rules are applied consistently.

Test ID	User/Role	Operation	Expected Result
TC01	User with bb1	Read	EEE records are accessible under the configured Read ACL condition
TC02	User without required role	Read	Protected records are not accessible
TC03	Admin	Read	Administrator can access records
TC04	User with bb1 + bb2	Create	New operation is available according to Create ACL
TC05	User with bb1 + bb2 + bb3	Write	Permitted EEE records can be edited
TC06	User with bb1 + bb2 + bb3 + bb4	Delete	Permitted EEE records can be deleted
TC07	User with insufficient role	Write/Delete	Operation is denied

6.2 Verification Checklist

- Impersonate EEE User and open u_institution_details list.
- Verify the Read restriction.
- Impersonate Admin and verify unrestricted administrative access.
- Add bb2 and verify the New/Create operation.
- Add bb3 and verify editing.
- Add bb4 and verify deletion.
- Verify unauthorized operations are blocked.

7. PROJECT DOCUMENTATION PHASE

7.1 Documentation Contents

- Project title and description
- Problem statement
- Objectives
- Requirements
- User and role details
- Table and field design
- ACL design
- Script logic explanation
- Implementation steps
- Test cases and results
- Screenshots of configuration and execution
- Outcome
- Limitations
- Future enhancements
- Conclusion
- References

7.2 Suggested Screenshots

30. User creation screen
31. Role bb1 creation screen
32. Roles bb2, bb3 and bb4
33. Institution Details table
34. Table fields
35. Sample records with different branches
36. Read ACL configuration
37. Read ACL script
38. Create ACL
39. Write ACL
40. Delete ACL
41. EEE User list view
42. Admin list view
43. New button verification
44. Edit verification
45. Delete verification

7.3 Limitations

- The example focuses on a specific branch-based access rule.
- Role and ACL configuration must be maintained carefully as the application grows.
- Testing should cover all relevant role combinations before production use.
- ACL behavior can depend on ServiceNow security configuration and the exact table/field setup.

7.4 Future Enhancements

- Add more branch-specific roles and conditions.
- Create reusable ACL design patterns for other institutional tables.

- Add automated test cases for security regression testing.
- Create an audit/reporting view for access-related events.
- Extend the model with department, course or faculty-based access rules.

8. PROJECT DEMONSTRATION PHASE

8.1 Demo Video Script

46. Introduce the project title: Script-Controlled ACL – Restrict Record Access Based on Field Value.
47. Explain that the project is implemented in ServiceNow.
48. Explain the security problem and why record-level access control is required.
49. Show the EEE User and the custom roles bb1, bb2, bb3 and bb4.
50. Show the Institution Details table and its fields.
51. Show sample records containing ECE, EEE and CSE values.
52. Open and explain the Read ACL.
53. Demonstrate Read access using the EEE User.
54. Demonstrate administrator access.
55. Show the Create ACL and verify the New operation.
56. Show the Write ACL and verify editing.
57. Show the Delete ACL and verify deletion.
58. Show the final output and explain the security outcome.

8.2 Demo Video Checklist

- Screen sharing enabled
- Student voice-over included
- Project name explained
- Purpose explained
- Use/benefits explained
- Working process demonstrated
- Final output shown
- Google Drive sharing set to Anyone with the link can view

PROJECT OUTCOME

By completing this project, learners understand how ServiceNow ACLs can enforce record-level security using roles, data conditions and scripts. The project demonstrates separate control over Read, Create, Write and Delete operations and shows how administrator access can be retained while unauthorized users are restricted.